

SEGURANÇA DE REDES

UFN - Sistemas de Informação

Professor José Carlos Neto (j.neto@ufn.edu.br)

Aula 02 · 18h25 às 22h00

Unidade 1 — Segurança de redes locais e de longa distância



O que vimos na Aula 01

Antes de seguir, um resumo rápido dos conceitos que vamos usar hoje como base.

- **Segurança Digital**

Proteger informações, contas e sistemas para que ninguém não autorizado acesse, altere ou derrube o que importa.

- **A Tríade CIA**

Confidencialidade, Integridade e Disponibilidade — as três propriedades que toda informação precisa manter.

- **Ativos, ameaças, vulnerabilidades, riscos e controles**

O vocabulário base para falar sobre segurança de forma estruturada.

- **Defesa em profundidade e Zero Trust**

Nenhum controle é infalível sozinho; cada acesso deve ser verificado, sempre.

- **Casos reais**

Colonial Pipeline, MGM Resorts e Stuxnet mostraram como falhas de rede e de processo viram incidentes graves.

O que veremos hoje

Da segurança de redes locais e de longa distância até os primeiros passos de um teste de invasão.

01 Unidade 1 — Segurança de redes locais e de longa distância

02 Senhas: por que esse assunto é tão delicado

03 Subunidade 1.1 — Introdução a testes de invasão

04 Modelo TCP/IP, endereçamento e portas de serviço

05 Ataques de rede comuns e um estudo de caso real

06 Fases e tipos de um teste de invasão autorizado

07 Atividade prática e encaminhamentos

— UNIDADE 1

Segurança de redes locais e de longa distância

Modalidade: Presencial · Turma noturna · 18h25 às 22h00

O que estudaremos?

Nesta unidade estudaremos os conceitos sobre Segurança Digital, o conceito de invasão, e como se realizam procedimentos que amenizam as possibilidades de nossos servidores serem invadidos por Hackers. Para isso, faremos exercícios em sala de aula para irmos fixando os conhecimentos.

Segurança Digital

Invasão

Crackers

Servidores

Procedimentos preventivos

Nota: um cracker é quem usa técnicas de invasão para fins maliciosos — diferente do hacker ético, que usa as mesmas técnicas de forma autorizada e para proteger.

O que aprenderemos?

Estudaremos a Teoria sobre a Segurança de Sistemas, que permitirá compreendermos como os invasores conseguem obter conhecimento sobre as nossas redes, nossos servidores e, conseqüentemente, nossas vulnerabilidades.



Reconhecimento

O invasor mapeia a rede: hosts ativos, serviços expostos, versões de software.



Enumeração

Detalha o que foi encontrado: portas abertas, protocolos, usuários e permissões.



Exploração

Usa uma vulnerabilidade conhecida (ou não) para obter acesso não autorizado.

Por que uma senha é tão delicada para a segurança?

Sobre o que refletiremos: vamos discutir o porquê de termos senhas para acesso aos computadores, e por que esse assunto é tão delicado para a segurança — mesmo antes de falarmos de qualquer ferramenta técnica.



Senhas na prática: o que realmente protege

Comprimento importa mais que complexidade artificial — e nenhuma senha sozinha é suficiente.



Comprimento > complexidade

Uma frase longa ("cavalo-azul-comendo-maçã") é mais forte e mais fácil de lembrar que "P@ssw0rd!".



Nunca reaproveitar

A mesma senha em vários serviços significa que um vazamento compromete todos eles de uma vez.



Autenticação multifator (MFA)

Mesmo uma senha vazada não basta se o acesso exige também um segundo fator (app, token, biometria).



Gerenciador de senhas

Permite usar uma senha longa e única por serviço, sem depender da memória.

Como uma senha é comprometida

Raramente é "quebrada" por força bruta pura — geralmente é obtida por um caminho mais simples.

Vazamento de dados

A senha (ou seu hash) é exposta em um incidente de segurança de terceiros e reaparece em bancos de dados de vazamentos. (DeHashed, HIBP, IntelX, etc.)

Reaproveitamento

Uma senha vazada em um serviço é testada automaticamente em dezenas de outros (credential stuffing).

Phishing

O usuário é enganado e digita a senha diretamente em um site ou formulário falso.

Brute Force / Password Spray / Dicionário

Tentativas automatizadas e massivas — eficazes contra senhas curtas ou previsíveis.

— SUBUNIDADE 1.1

Introdução a testes de invasão

Da comunicação entre computadores à identificação de falhas em protocolos.

Competências e objetivos

COMPETÊNCIAS

Compreender o que são vulnerabilidades em sistemas computacionais, de forma a identificar falhas em protocolos.

Isso exige entender não só "o que é um protocolo", mas como duas máquinas conversam de fato — porque toda vulnerabilidade de rede é, no fundo, um desvio do que o protocolo previa.

OBJETIVOS

Identificar detalhadamente os protocolos necessários para a existência de uma rede.

- Reconhecer as camadas do modelo TCP/IP e o papel de cada uma
- Diferenciar endereço IP, máscara de sub-rede e porta de serviço
- Relacionar cada camada a um tipo possível de ataque

Da rede local à internet

Entendimento da comunicação entre computadores, desde a rede local (LAN) até a internet (WAN).



Rede local (LAN)

Poucos hosts, mesmo domínio físico ou lógico — uma sala, um prédio, um campus. Comunicação direta, geralmente via switch.



Rede de longa distância (WAN)

Interconecta redes locais distantes entre si — a própria internet é a maior WAN que existe. Depende de roteamento entre redes.



Internetworking

O conjunto de protocolos (a suíte TCP/IP) que permite que redes diferentes, de fabricantes e tecnologias diferentes, conversem entre si.

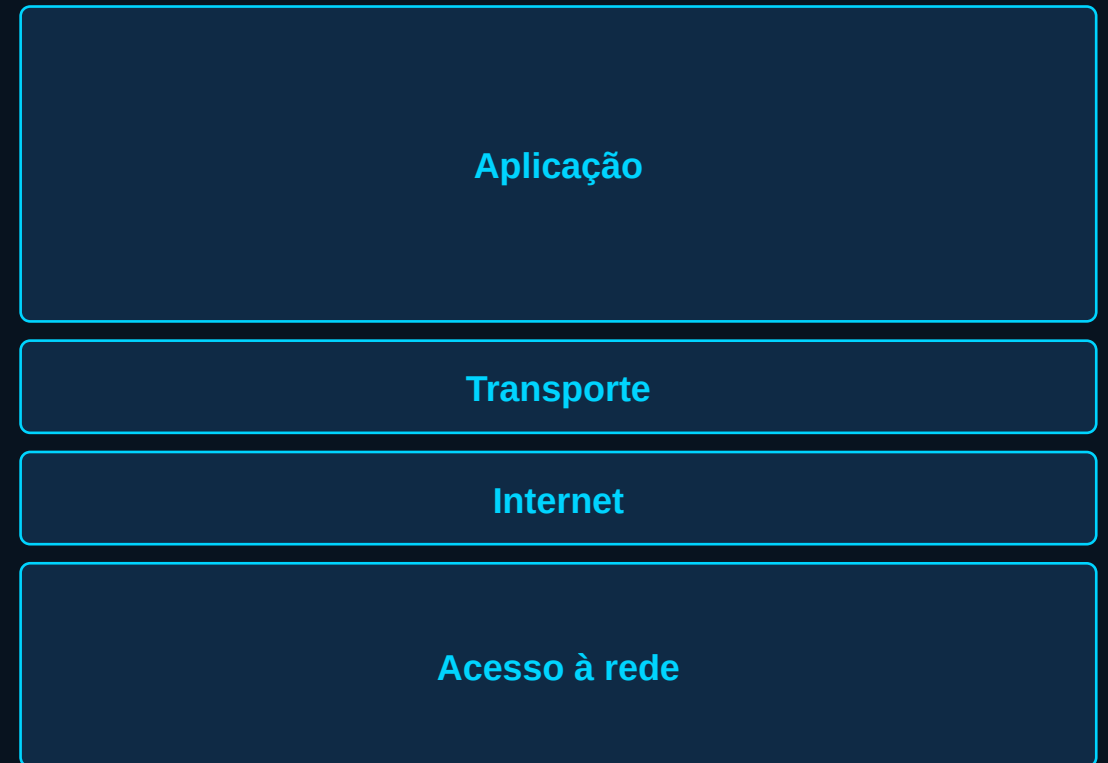
Modelo OSI x Modelo TCP/IP

O OSI é o modelo de referência teórico, com 7 camadas; o TCP/IP é o modelo prático, com 4 camadas, que a internet realmente usa.

OSI (7 camadas)



TCP/IP (4 camadas)



As quatro camadas do TCP/IP

Cada camada resolve um problema diferente da comunicação — e cada uma tem suas próprias vulnerabilidades.

4 Aplicação

HTTP, DNS, SSH, FTP — o que o usuário e os programas efetivamente usam.

3 Transporte

TCP e UDP — organiza a entrega de dados entre processos.

2 Internet (Rede)

IP — endereça e encaminha pacotes entre redes diferentes.

1 Acesso à rede

Ethernet, Wi-Fi, MAC — coloca os bits fisicamente no meio.

Camada de Aplicação

Onde usuários e programas efetivamente se comunicam — é também a camada mais exposta a ataques.

O que ela faz

Define como aplicações trocam dados: formato das mensagens, quem inicia a conversa e o que cada lado espera receber.



HTTP/HTTPS

Navegação web — o "S" indica que o tráfego é criptografado.



DNS

Traduz nomes (exemplo.com) em endereços IP.



SSH

Acesso remoto administrativo, criptografado.



FTP

Transferência de arquivos — historicamente sem criptografia.

Ponto de atenção para testes de invasão: bandeiras de serviço (banners), versões desatualizadas e credenciais fracas nessa camada são o alvo mais comum de reconhecimento inicial.

Camada de Transporte

Organiza a entrega de dados entre processos — é aqui que vivem as portas.



TCP

Confiável e orientado a conexão. Antes de trocar dados, cliente e servidor negociam o three-way handshake (SYN, SYN-ACK, ACK). Garante entrega e ordem — usado por HTTP, SSH, FTP.



UDP

Rápido e sem conexão. Envia os dados sem garantir entrega nem ordem. Usado quando velocidade importa mais que confiabilidade — DNS, streaming, VoIP.

Por que isso importa para um teste de invasão: identificar se uma porta responde por TCP ou UDP muda completamente a técnica de varredura — e o tipo de serviço provável por trás dela.

Camada de Internet (Rede)

Responsável por endereçar hosts e encaminhar pacotes entre redes diferentes.

IP (Internet Protocol)

Endereça cada host de forma (teoricamente) única e leva o pacote de origem até o destino, rede após rede.

Roteamento

Cada roteador decide, com base na tabela de rotas, para qual próximo salto encaminhar o pacote.

ICMP

Protocolo de controle e diagnóstico — usado por ferramentas como ping e traceroute, e também por técnicas de reconhecimento de rede.

IPv4 x IPv6: panorama rápido

O IPv4 ainda domina as redes locais que veremos hoje, mas o IPv6 já é maioria de tráfego em vários países.



IPv4

32 bits · cerca de 4,3 bilhões de endereços possíveis · notação decimal (192.168.1.10) · praticamente esgotado desde 2011, sustentado hoje por NAT.



IPv6

128 bits · quantidade de endereços praticamente inesgotável · notação hexadecimal (2001:db8::1) · não depende de NAT para funcionar.

Camada de Acesso à Rede

Coloca os dados fisicamente no meio de transmissão — cabo, fibra ou rádio.



Ethernet

Padrão para redes cabeadas locais. Organiza os dados em quadros (frames) endereçados por MAC.



Endereço MAC

Identificador físico, único por fabricante, gravado na placa de rede — usado apenas dentro do mesmo segmento local.



Wi-Fi

Versão sem fio do mesmo princípio, com desafios extras de segurança pela natureza aberta do meio de transmissão.



ARP

Traduz endereço IP em endereço MAC dentro da rede local — alvo clássico de ataques de interceptação (ARP spoofing).

Classes de endereços IP e CIDR

O IPv4 nasceu dividido em classes fixas — hoje, o CIDR permite dividir a rede em qualquer tamanho.

Classe	Faixa de endereços	CIDR	Uso típico
Classe A	1.0.0.0 – 126.255.255.255	/8	Redes gigantes (mais de 16 milhões de hosts) — hoje raras fora de grandes operadoras
Classe B	128.0.0.0 – 191.255.255.255	/16	Redes médias, comuns em universidades e empresas grandes
Classe C	192.0.0.0 – 223.255.255.255	/24	Redes pequenas — a mais usada em redes locais e domésticas

CIDR (Classless Inter-Domain Routing): em vez de ficarmos presos às classes fixas, indicamos o tamanho da rede diretamente na máscara — como em 192.168.1.0/26, uma sub-rede menor que uma Classe C inteira.

Endereçamento IP e sub-redes

Todo host numa rede precisa de um endereço único — e uma forma de saber quem mais está "por perto".

ESTRUTURA DE UM IPv4

192.168.1.10 / 24

192.168.1 → identifica a rede

.10 → identifica o host

/24 → máscara de sub-rede (255.255.255.0)

Quanto maior o número após a barra, menor a quantidade de hosts possíveis naquela rede — e menor o tamanho da "vizinhança".

POR QUE ISSO IMPORTA

- Sub-redes limitam o alcance de um ataque: um invasor dentro de uma sub-rede pequena enxerga menos hosts diretamente.
- Segmentação de rede é um controle de segurança — separa, por exemplo, a rede de convidados da rede administrativa.
- Entender endereçamento é pré-requisito para qualquer varredura de rede (scan) feita em um teste de invasão autorizado.

Calculando uma sub-rede, passo a passo

Exemplo: dividir 192.168.5.0/24 em sub-redes de /26.

1 Quantos bits eu "tomei emprestado"?

De /24 para /26 → 2 bits a mais para a rede ($26 - 24 = 2$).

2 Quantas sub-redes isso cria?

$2^2 = 4$ sub-redes possíveis.

3 Quantos hosts cabem em cada uma?

Restam $32 - 26 = 6$ bits para hosts → $2^6 - 2 = 62$ hosts utilizáveis (subtraindo rede e broadcast).

4 Quais são os blocos?

192.168.5.0/26 · 192.168.5.64/26 · 192.168.5.128/26 · 192.168.5.192/26

NAT: por que sua rede não expõe IPs internos

Network Address Translation traduz endereços privados (internos) em um único endereço público, na saída para a internet.

Faixas de IP privado (não roteáveis na internet): 10.0.0.0/8 · 172.16.0.0/12 · 192.168.0.0/16



Economiza IPs públicos

Toda uma rede local sai para a internet usando um único endereço IPv4 público — essencial diante do esgotamento do IPv4.



Ganho de segurança indireto

Hosts internos não são diretamente endereçáveis pela internet — um invasor externo não consegue simplesmente "apontar" para eles.



Mas não substitui um firewall

NAT não foi desenhado como controle de segurança — é sempre complementado por regras explícitas de firewall.

Portas e serviços comuns

A porta identifica qual serviço, dentro do host, deve receber os dados. Conhecê-las é o primeiro passo de qualquer reconhecimento de rede.

Porta	Protocolo	Serviço	Observação de segurança
22	TCP	SSH	Acesso remoto administrativo — alvo comum de força bruta
53	TCP/UDP	DNS	Resolução de nomes — pode vazar estrutura interna da rede
80 / 443	TCP	HTTP / HTTPS	Web — 443 deve ser sempre preferido por usar criptografia
445	TCP	SMB	Compartilhamento de arquivos Windows — histórico de falhas graves
3389	TCP	RDP	Área de trabalho remota — nunca deveria ficar exposta à internet
23	TCP	Telnet	Acesso remoto sem criptografia — praticamente obsoleto por insegurança

Firewalls e ACLs: o primeiro controle de rede

Decidem, pacote a pacote, o que entra e o que sai — com base em regras explícitas.



Firewall

Analisa o tráfego que passa por ele e aplica regras: permite ou bloqueia com base em IP de origem/destino, porta e protocolo.



ACL (Access Control List)

Lista ordenada de regras de permissão/negação, aplicada em um roteador ou switch — a lógica por trás de muitos firewalls.

Princípio prático: negar tudo por padrão, e liberar explicitamente só o que é necessário — o mesmo espírito de acesso mínimo do Zero Trust, visto na Aula 01.

VLANs e segmentação de rede

Dividir uma rede física em várias redes lógicas isoladas — mesmo cabo, tráfego separado.

Uma VLAN (Virtual LAN) agrupa portas de switch em domínios de broadcast separados, mesmo que os equipamentos estejam fisicamente na mesma rede — como se fossem redes independentes.



Isolamento por finalidade

Rede de convidados, rede administrativa e rede de servidores em VLANs separadas — mesmo compartilhando o mesmo switch físico.



Redução da superfície de ataque

Um host comprometido em uma VLAN não enxerga diretamente hosts de outra — limita o "movimento lateral" de um invasor.



Organização e desempenho

Também reduz tráfego de broadcast desnecessário e organiza a rede por departamento ou função.

Wi-Fi: WPA2/WPA3 e riscos de redes abertas

O meio de transmissão sem fio é, por natureza, mais exposto — qualquer um dentro do alcance pode "ouvir".

Rede aberta (sem senha)

Todo o tráfego pode ser capturado por qualquer pessoa próxima — nunca deve ser usada para nada sensível sem VPN.

WPA2

Padrão consolidado, com criptografia forte quando bem configurado — ainda vulnerável a ataques de força bruta contra senhas fracas.

WPA3

Sucessor do WPA2, com proteção adicional contra tentativas offline de quebra de senha e criptografia individualizada por sessão.

Ataques comuns de rede

Ataques que exploram diretamente o funcionamento dos protocolos que vimos hoje.



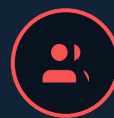
Sniffing

Captura passiva do tráfego de rede — o Wireshark, visto na Aula 01, é uma ferramenta de sniffing legítima e usada por profissionais.



Spoofing

Falsificação de identidade na rede: IP spoofing (forjar o endereço de origem) ou ARP spoofing (forjar a tradução IP-MAC).



Man-in-the-Middle (MITM)

O atacante se posiciona entre duas partes e intercepta — ou altera — a comunicação sem que nenhuma delas perceba.



Negação de Serviço (DoS/DDoS)

Sobrecarrega um serviço com requisições até torná-lo indisponível — quebra a Disponibilidade da tríade CIA.

Mirai Botnet

2016



Os fatos

- Malware infectou centenas de milhares de câmeras e roteadores domésticos (dispositivos IoT)
- A infecção explorava um conjunto pequeno de usuários e senhas padrão de fábrica, nunca alterados
- Os dispositivos formaram uma botnet usada em um dos maiores ataques DDoS já registrados
- O alvo incluiu a Dyn, provedora de DNS — tirando do ar serviços como Twitter, Netflix e Reddit

O que fica de lição

Nenhuma técnica sofisticada foi necessária — apenas portas de administração (como Telnet, porta 23) expostas à internet, com credenciais padrão nunca trocadas. É a mesma lição de reconhecimento e portas que vimos hoje: o que está exposto, será encontrado.

Da rede ao teste de invasão

Cada camada que estudamos hoje corresponde a um passo real de um teste de invasão autorizado.



Reconhecimento

Mapear IPs, sub-redes e hosts ativos na rede-alvo (camada de Internet).



Varredura de portas

Descobrir quais portas TCP/UDP estão abertas em cada host (camada de Transporte).



Enumeração de serviços

Identificar qual aplicação e versão responde em cada porta (camada de Aplicação).



Relato

Documentar tudo em um relatório técnico — um teste de invasão sem laudo não tem valor formal.

Importante: testar redes e sistemas sem autorização formal é crime (Lei 12.737/2012 e Código Penal). Tudo isso só é praticado dentro de laboratório controlado.

Fases de um teste de invasão

Metodologias como o PTES organizam o trabalho em fases — reconhecimento e varredura, vistos hoje, são apenas o início.

1

Planejamento e acordo (Rules of Engagement)

Define escopo, horários, o que pode e não pode ser testado, e a autorização formal por escrito.

2

Reconhecimento

Coleta de informações públicas e de rede sobre o alvo (o que vimos hoje: IPs, portas, serviços).

3

Varredura e enumeração

Mapeamento detalhado de vulnerabilidades potenciais nos serviços encontrados.

4

Exploração

Tentativa controlada de uso de uma vulnerabilidade para obter acesso.

5

Pós-exploração

Avalia até onde o acesso obtido permitiria avançar, sem causar dano real.

6

Relatório

Documentação técnica das falhas encontradas, evidências e recomendações de correção.

Tipos de teste de invasão

A quantidade de informação prévia dada ao testador muda completamente a abordagem.



Black box

O testador não recebe nenhuma informação prévia — simula um atacante externo real, começando do zero pelo reconhecimento.



Grey box

O testador recebe informações parciais (por exemplo, uma conta de usuário comum) — simula uma ameaça interna limitada.



White box

O testador recebe acesso completo: topologia de rede, código-fonte, credenciais — foca em profundidade, não em descoberta.

Testar sem autorização é crime

Todo o conteúdo técnico visto hoje só pode ser praticado dentro de ambiente autorizado e controlado.

Lei 12.737/2012 (Lei Carolina Dieckmann) — tipifica como crime a invasão de dispositivo informático alheio, mediante violação indevida de mecanismo de segurança, para obter, adulterar ou destruir dados.



Autorização por escrito

Todo teste de invasão profissional exige um contrato formal definindo escopo — sem isso, é crime, mesmo com boas intenções.



Código Penal

Dependendo do caso, também pode configurar outros crimes: interrupção de serviço, dano, ou violação de correspondência eletrônica.



Laboratório controlado

Por isso, toda prática de invasão nesta disciplina ocorre em ambientes isolados, criados especificamente para o exercício.

Exercícios de fixação

Antes da atividade em duplas, resolvam individualmente os itens abaixo — revisamos as respostas em seguida.

- 1 Classifique cada item na camada correta do TCP/IP: HTTP, ARP, UDP, Ethernet.
- 2 Qual a máscara de sub-rede equivalente a /27? Quantos hosts utilizáveis ela permite?
- 3 Um pacote chega na porta 443 de um servidor. Qual protocolo de transporte e qual serviço provavelmente estão envolvidos?
- 4 Em uma frase, explique a diferença prática entre TCP e UDP.
- 5 Por que um endereço IP privado (ex.: 192.168.0.5) nunca aparece diretamente na internet?

Prática: calculando vizinhanças de rede

Em duplas, resolvam os três cenários abaixo. Depois, cada dupla compartilha uma resposta.

Cenário A

Uma empresa tem o bloco 192.168.10.0/24. Quantos hosts utilizáveis existem nessa rede? Qual o endereço de broadcast?

Cenário B

Você precisa dividir 192.168.20.0/24 em 4 sub-redes de tamanho igual. Qual máscara usar, e quais os blocos resultantes?

Cenário C

Dois hosts, 10.0.5.12/26 e 10.0.5.80/26, estão na mesma sub-rede? Justifique com o cálculo.

Glossário da aula

LAN / WAN — Rede local x rede de longa distância (interconecta LANs)

Porta — Número que identifica um serviço específico dentro de um host

Máscara / CIDR — Define quantos bits de um endereço IP identificam a rede

Firewall / ACL — Controles que decidem o que entra e sai de uma rede

MITM / Spoofing — Interceptação ou falsificação de identidade na comunicação

TCP/IP — Suíte de protocolos que faz a internet funcionar, em 4 camadas

Endereço IP — Identificador lógico e (teoricamente) único de um host na rede

NAT — Traduz IPs privados internos para um IP público na saída

VLAN — Segmentação lógica de uma rede física em domínios isolados

Black/Grey/White box — Níveis de informação prévia dados a um teste de invasão

Atividade discente efetiva



Para a próxima aula, uma lista com exercícios para fixação do conteúdo, que serão corrigidos no início da próxima aula.



Referência bibliográfica

TANENBAUM, A. S. Redes de computadores. 4. ed. Rio de Janeiro: Campus, 2003.

O que vimos hoje

Recapitulando os pilares da Aula 02.



O conceito de invasão e o papel do cracker



Firewalls, VLANs e Wi-Fi como controles de rede



Senhas: como se tornam delicadas e como se protegem



Ataques comuns de rede e o caso Mirai Botnet



As quatro camadas do modelo TCP/IP



Fases, tipos e aspectos legais de um teste de invasão



Endereçamento IP, sub-redes, CIDR e portas de serviço



Prática de cálculo de vizinhanças de rede

Subunidade 1.2 — Definições básicas sobre protocolos de testes

- Reconhecer os protocolos de rede e suas aplicações práticas
- Aprofundar a tradução de endereços de rede (NAT): aplicação e consequências de seu uso
- Consolidar a identificação de falhas em protocolos como base para os próximos testes de invasão

Até a próxima aula: revisem o cálculo de sub-redes feito hoje e tragam uma dúvida ou curiosidade sobre segurança de redes para começarmos a conversa.

— ENCERRAMENTO

Dúvidas?

Professor José Carlos Neto

j.neto@ufn.edu.br

